

UST-2026-09-26-17

Un candado: Cloudflare Access es el segundo factor; el hub y StartUp Admin dejan de pedir TOTP y de cerrar la sesión a los 30 min

AS-BUILT · construido y desplegado el 26-sep en carril técnico (Juanjo decide, Pilar y Lucía corroboran). La UST se escribe el mismo día con lo construido y sus desviaciones (regla del 7-sep: la cadena entera, sin excepciones). Firma de Juanjo pendiente; verificación humana (que Pilar y Lucía entren) pendiente.

1 · El pedido, literal

Juanjo, 26-sep 2026, por la tarde, tras «No me deja entrar» de Pilar (captura del 21-sep con «canceling statement due to statement timeout» dentro de la caja «sin acceso») y «el Piloto no carga»:

«simplificar el proceso de autenticación... que no se pida excepto si cambia de ordenador o al expirar el token»

Lectura: UN reto interactivo, recordado por dispositivo; el resto de la sesión se renueva sola. No «quitar seguridad», sino repartirla: cuatro candados en fila (Access + contraseña + TOTP + cierre a los 30 min) habían conseguido que las dos founders dejaran de entrar — la seguridad protegía el hub de sus dueñas.

2 · Lo que había (medido, no de memoria)

Qué	Medido
Capa 1 · Cloudflare Access	PIN por correo a los 4 gmails founders (team larama-familia-2026, cuenta outlook). Sesión con la duración por defecto; las dos aplicaciones (hub y admin.) con su propia política.
Capa 2 · Supabase	Email + contraseña (signInWithPassword) en MIS o Waitlist; StartUp Admin con su propia puerta (la sesión no viaja entre dominios).
Capa 3 · TOTP (r13)	<code>`is_admin_mfa()`</code> exigía aal2 a quien tuviera TOTP verificado (hub) e <code>`is_sa_admin()`</code> lo exigía SIEMPRE (StartUp Admin) → sin TOTP dado de alta, la contabilidad era una puerta cerrada para Pilar (avisado en cada digest desde el 5-ago, r23).
Capa 4 · cierre por inactividad	30 min (po218, r16) en hub-navbar y en adminsite → cada mañana, todo otra vez. Y el pase directo hub↔admin acuñaba sesión aal1 → a un admin con TOTP enrolado le dejaba el hub «roto» (r24).
Y el Piloto muerto	No era acceso: <code>`admin_pilot_overview`</code> se pasaba de los 8 s de PostgREST por las 630.083 filas basura de la waitlist (UST-18). El hub lo pintaba en la caja «sin acceso», así que parecía un QUINTO candado.
Resultado	Pilar (21-sep) y Lucía sin poder entrar; Juanjo entrando por costumbre. Medido antes de tocar: sonda <code>`2026-09-26-sonda-recalibracion-s19.sql`</code> + <code>`baseline-20260926-191427.txt`</code> .

Analogía: antes había cuatro puertas con cuatro llaves distintas una detrás de otra, y la última se cerraba sola cada media hora. Ahora hay un portero (Cloudflare Access) que te reconoce durante un mes por dispositivo, una llave de casa que se guarda en el llavero del navegador (la sesión de Supabase con refresh token), y la caja fuerte (TOTP) queda para quien quiera usarla.

3 · Cambios, fila a fila (as-built)

Qué	Qué se construyó	Cómo se verificó
C1 · Las dos puertas SQL	<code>`2026-09-26-un-candado-auth.sql`</code> : <code>`is_admin_mfa()`</code> e <code>`is_sa_admin()`</code> pasan a <code>`exists(select 1 from admins where user_id = auth.uid())`</code> . Mismo nombre (lo llaman >100 funciones), significado nuevo, y un <code>`comment on function`</code> que dice la verdad nueva («Puerta del hub. Un candado...»). Dos items S19 en el tablero (hecho/WEB).	Ejecutado por Juanjo el 26-sep: <code>true · true · 0 · 4</code> (las dos definiciones llevan el comentario nuevo · ninguna mira <code>`aal`</code> · 4 admins registradas). Vigilado por <code>`admin-tests`</code> (la última definición de <code>`is_sa_admin`</code> no contiene <code>`aal`</code>).

Qué	Qué se construyó	Cómo se verificó
C2 · Hub: sin cierre por inactividad ni reto TOTP automático	`_integration/hub-navbar.html`: `LIMITE=0` (el bloque queda en el código para volver con `30*60*1000`); borra `ns_idle_aviso`/`ns_idle_ts` del localStorage; `nsMfaReforzar()` ya no se auto-lanza. Sale en TODAS las páginas del hub vía integrate.py.	po254 en producción (ns-build 2609-204258, webdeploy 43c69ed); web-tests 93/93; pre-deploy verde; datos-en-html 87 (trinquete intacto).
C3 · StartUp Admin: misma regla	`repos/adminsite/index.html`: cierre por inactividad apagado; `afterSignIn()` entra directo; aviso clicable «Sesión sin refuerzo TOTP (opcional). Toca para reforzarla» → `gstep(3)` (el paso TOTP sigue existiendo, ya no bloquea).	Deploy StartUp Admin (Juanjo, 26-sep); admin-tests 52/52 (incluye: la puerta ofrece TOTP como opcional y no lo exige).
C4 · Zero Trust: sesión de 30 días por dispositivo	Cloudflare One → Access controls → Access settings: sesión global a «1 month»; Applications → hub y admin. → Configure → Overview → Session Duration «1 month».	Hecho por Juanjo en el panel («todo hecho», 26-sep). La verificación real es humana: Pilar y Lucía entran un día y vuelven al siguiente sin PIN.
C5 · TOTP como refuerzo opcional	`hub/mfa.html` sigue vivo (enroll/challenge/verify/unenroll); `admin_mfa_readiness()` sigue informando. Ninguna RPC exige aal2. El factor de quien lo activó NO se borra.	Leído del código de mfa.html el 26-sep; `admin-tests` vigila que ninguna puerta lo exija.
C6 · Lo que NO cambia	RLS; service_role solo en Vault/Edge; `is_admin_mfa()` en TODA RPC admin nueva; las 8 páginas legales; el rebote pages.dev → dominio propio (r26-c); el pase directo hub↔admin.	smoke-prod tras el Deploy Web (candado del hub como anónimo = opaqueredirect).

4 · Análisis de impacto

Dónde	Qué toca	Qué NO toca
Base de datos	Dos funciones (`is_admin_mfa`, `is_sa_admin`) y dos filas nuevas en `dev_backlog`.	Tablas, RLS, el resto de RPC (siguen llamando a la misma puerta), `auth.mfa factors` (nadie pierde su TOTP).
Hub (webdeploy)	`hub-navbar.html` (inyectado en todas las páginas del hub) → po254.	La web pública V2, los formularios, el hub gated de Design, los adjuntos.
StartUp Admin (adminsite)	`index.html` (gate + idle) y `admin-tests`.	Contabilidad `sa_*`, asientos, RPC.
Cloudflare	Duración de sesión de Access (global + 2 aplicaciones).	Políticas de quién entra (los mismos 4 gmails), WAF, Pages.
Quién lo recibe	Las 4 cuentas de la tabla `admins` (founders; el hub y StartUp Admin). Ninguna tester, ninguna usuaria de la app.	App nativa, PWA, correos.
Riesgo asumido	Un dispositivo robado con sesión viva entra durante ≤30 días sin reto. Mitigación: revocar en Zero Trust (Access → revoke sessions) + Supabase (cerrar sesiones del usuario); TOTP opcional para quien quiera el tercer factor.	—

Desviación declarada: se retira UST-06 G1 (cierre a los 30 min) y el listón aal2 de r13 («dos puertas, dos listones»). Volver atrás es un `create or replace` de las dos funciones (versión r13 en `2026-08-05-startup-admin.sql` y la de `is\_admin\_mfa` en su fichero de origen) + `LIMITE=30\*60\*1000` en navbar y adminsite.

5 · Decisiones (tomadas por Juanjo el 26-sep, carril técnico)

#	Propuesta	Alternativa	Decisión
D1	Cloudflare Access es el ÚNICO reto interactivo y hace de segundo factor (posesión del buzón founder + cookie del dispositivo).	Mantener Access + TOTP y quitar solo el cierre a los 30 min.	DECIDIDO (Juanjo, 26-sep): la propuesta — Access único reto.
D2	Sesión de Access de 30 días por dispositivo (global y en las dos aplicaciones).	7 días.	DECIDIDO: 30 días («1 month» en Zero Trust, hecho por Juanjo).

#	Propuesta	Alternativa	Decisión
D3	Contraseña de Supabase UNA vez por dispositivo; la sesión se renueva sola (refresh token); cierre por inactividad APAGADO (`LIMITE=0`).	Cierre a las 8 h o al cerrar el navegador.	DECIDIDO: la propuesta — «que no se pida excepto si cambia de ordenador o al expirar el token».
D4	TOTP opcional: nadie lo pierde, ninguna RPC lo exige, no se auto-lanza; StartUp Admin lo ofrece con un aviso clicable.	Borrar los factores TOTP existentes.	DECIDIDO: la propuesta — TOTP opcional, nadie lo pierde.
D5	Se conserva el NOMBRE `is_admin_mfa()`/`is_sa_admin()` con significado nuevo (deuda declarada: >100 llamadas), con comentario que dice la verdad y test que vigila la última definición.	Renombrar a `is_admin()` y reescribir las >100 funciones.	DECIDIDO: la propuesta — mismo nombre, comentario + test.
D6	Desviación declarada de UST-06 G1 y del listón aal2 de r13; se documenta aquí y en CLAUDE.md.	—	DECIDIDO: desviación declarada.
D7	Carril técnico: Juanjo decide y ejecuta; Pilar y Lucía corroboran en el hub (doc 52).	Carril producto (firma previa de las dos).	DECIDIDO: carril técnico; corroboración pendiente de Pilar y Lucía.

6 · Baseline, verificación y marcha atrás

Momento	Qué se comprueba
PASO 0 · Baseline (antes de tocar)	`tools/baseline.sh` → `archive/logs/baseline-20260926-191427.txt` (sha de los 3 repos, sellos ns-build, candados de Access, OTA por runtime, copias). Definiciones anteriores de las dos funciones en el histórico de backend-sql (immutable).
Verificación del SQL	Última sentencia del fichero: true · true · 0 · 4. `admin-tests`: 52/52.
Verificación del hub	Deploy Web po254: pre-deploy verde, web-tests 93/93, datos-en-html 87, linkcheck verde; producción sirve ns-build 2609-204258; smoke-prod tras el deploy.
Verificación de StartUp Admin	Deploy StartUp Admin (tests → sellado → wrangler) ejecutado por Juanjo el 26-sep.
Verificación HUMANA (pendiente)	Pilar y Lucía: entrar hoy (PIN + contraseña una vez) y volver mañana sin que se pida nada; ☐ Piloto carga; StartUp Admin entra sin TOTP. Cuando lo digan, este documento se marca corroborado.
Marcha atrás	SQL: `create or replace` de las dos funciones desde su versión anterior (histórico). Hub: Cloudflare Pages → nutrisync-collective → Deployments → Rollback al deploy anterior a po254, o `LIMITE=30*60*1000` y nuevo po. StartUp Admin: Pages → nutrisync-admin → Rollback. Zero Trust: sesión a 24 h. Ninguna de las cuatro toca datos de usuarias.

7 · Cómo lo comprueban Pilar y Lucía

1. Abrir nutrisynccollective.com/hub → Cloudflare pide el PIN por correo (una vez) → entra.
2. Ir a ☐ MIS → email + contraseña del hub (una vez). Si no la recuerdan: «Contraseña olvidada» en la misma página (llega un correo de recuperación).
3. Abrir ☐ Piloto: carga en unos segundos (ya no «sin acceso» ni «statement timeout»).
4. Cerrar la pestaña. Al día siguiente, en el mismo ordenador: entra sin PIN y sin contraseña.
5. admin.nutrisynccollective.com (StartUp Admin): PIN por correo (una vez) + contraseña (una vez); NO pide el código de la app autenticadora. Arriba puede salir un aviso «Sesión sin refuerzo TOTP (opcional)»: se puede ignorar.
6. Si cambian de ordenador o de móvil: PIN + contraseña otra vez, y ya está hasta dentro de 30 días.

8 · La cadena

Paso	Estado
UST	Este documento (as-built del 26-sep). Se escribe el mismo día que se construye, con lo construido y sus desviaciones (regla del 7-sep).

Paso	Estado
Sign-off	Carril técnico: decidido por Juanjo en el chat (26-sep, tarde) y FIRMADO esa noche («UST-17 según las recomendaciones también») — firma electrónica simple abajo (huella SHA-256 + marca de tiempo). Pilar y Lucía corroboran en el hub.
Dev	SQL un-candado-auth · hub-navbar (LIMITE=0, sin auto-TOTP) · adminsite (gate, aviso opcional) · admin-tests (52) — 26-sep.
Test	admin-tests 52/52 · web-tests 93/93 · pre-deploy verde · datos-en-html 87 · linkcheck verde.
Deployment	SQL ejecutado (true · true · 0 · 4) · Deploy Web po254 (ns-build 2609-204258) · Deploy StartUp Admin · Zero Trust sesiones a 1 mes — todo el 26-sep.
Verification	Técnica hecha (sello en vivo, tests, verificación del SQL). Humana PENDIENTE: Pilar y Lucía entran y lo dicen.
hub + Notion	Hub: este doc 52 + adjunto en documentation/ust (po255). Notion: el workspace sigue sin bloques (desde el 8-sep) — la verdad para ellas es el hub; se anota en CLAUDE.md como pendiente.

Firmas

Persona	Rol	Conforme	Fecha
Juanjo Cebrián	Ingeniería y producto (D1–D7, carril técnico)		
Pilar González	CEO · cumplimiento (corrobora: el segundo factor es Access)		
Lucía Cebrián	COO · diseño (corrobora: entra y vuelve a entrar sin retos)		